MANAGED DETECTION AND RESPONSE · AI-LED, CLIENT-GOVERNED

HELIOS

One security operations platform for a managed security provider and every client it protects: every tool's alerts in one place, AI that contains threats in the first minutes, and rules each client approves.

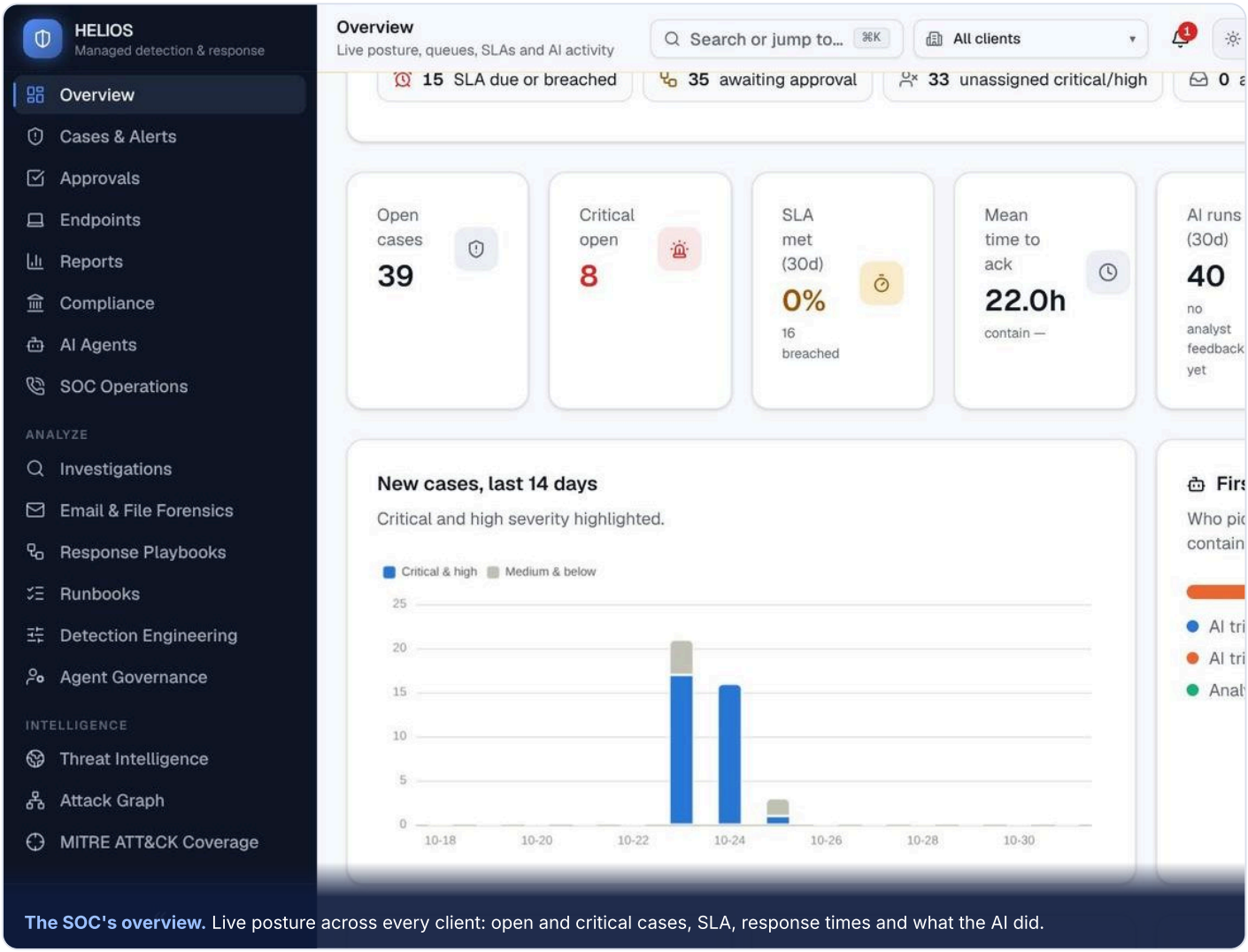
> **AI executes. HELIOS governs. The client authorises. The audit trail proves.**
> The AI performs initial containment itself, only within rules the client and HELIOS have approved. No AI can change those rules.

Minutes
from alert to initial containment, by the AI, within the client's rules

2 keys
every rule change needs the client's and HELIOS's approval

6 h
CERT-In clock, with the report drafted from the case

India
logs, keys and AI can stay in India (180-day retention)



The SOC's overview. Live posture across every client: open and critical cases, SLA, response times and what the AI did.

02 What HELIOS is
03 How it works
04 AI-led containment
05 Rules change only with approval
06 What it does
08 For your clients
09 Built to be trusted
10 Who uses it
11 AI models
12 Deploy it your way
13 Compliance in India
14 Getting started

01 · THE PLATFORM

One SOC for many clients, run by people and AI together

HELIOS runs a security operations centre for many client organisations at once. Each client's security tools stream alerts and logs into one place; HELIOS turns them into cases; AI agents investigate first and contain within the client's approved rules; analysts confirm, investigate and decide; clients see everything done for them. It also runs the business around it: quotes, pilots, contracts, GST invoices and India's regulatory reporting.

11 roles, from tier-1 analyst to the client's administrator

9 vendor log collectors, plus push and a signed forwarder

7 native response connectors acting through the client's tools

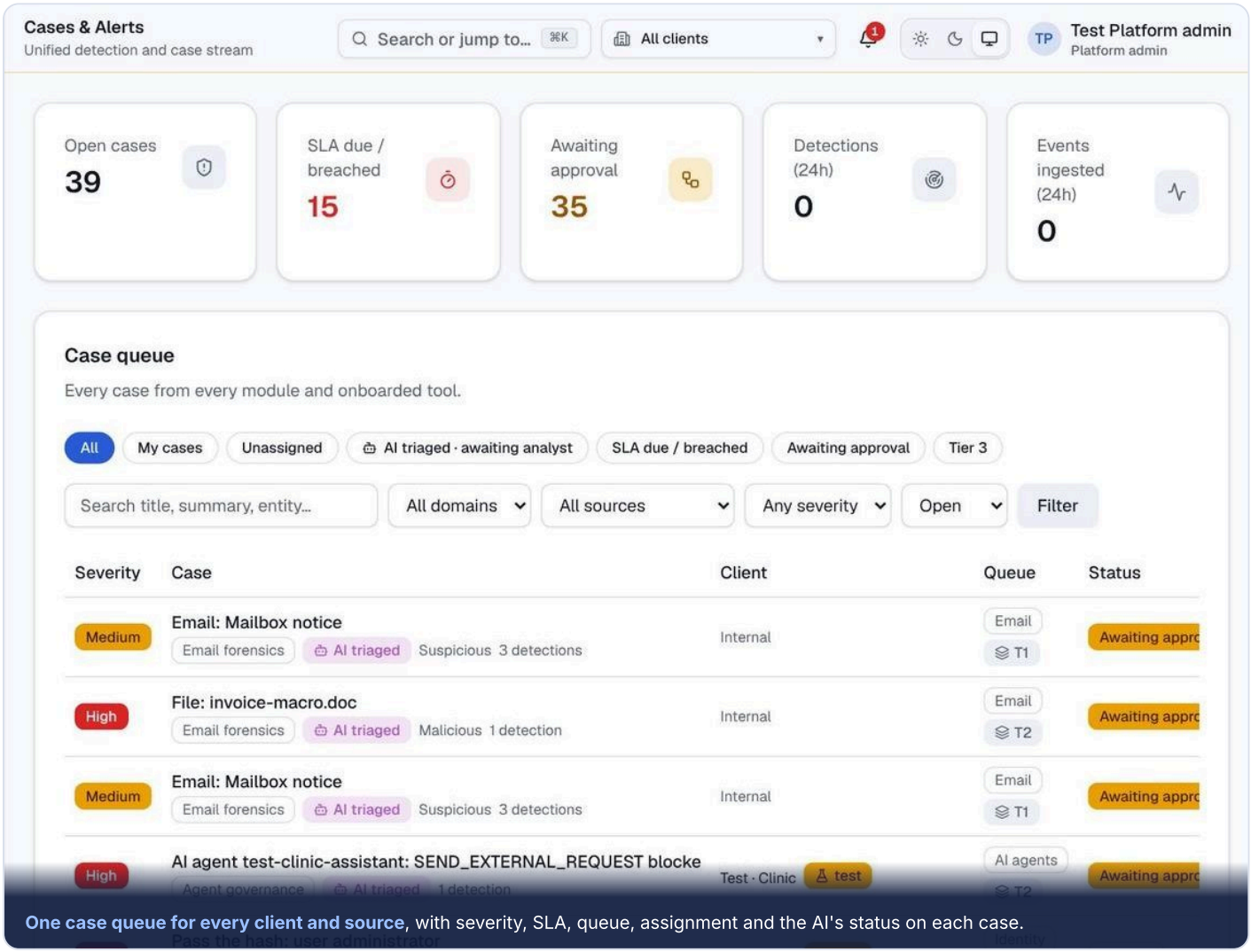
4 kinds of AI: Anthropic, Amazon Bedrock, Azure OpenAI, local models

The problem

- Alerts arrive from dozens of tools across many clients, in different formats, faster than a small team can read them.
- Attacks move in minutes; waiting for a person to wake up and approve every first step costs the client.
- Automation helps only if each client can trust it: what it may touch, when, and who says yes.
- Clients must see what was done, approve what matters and meet their regulators' clocks.

The HELIOS answer

- **One queue** for every source, related alerts joined into one case, SLA clocks from the client's plan.
- **AI first response**: every case triaged with cited evidence, and initial containment run by the AI within the client's approved rules.
- **Client-governed rules** that bind the AI, playbooks and people; changed only with the client's and HELIOS's approval.
- **A client portal** for incidents, approvals, reports, the rulebook and the contract.



One case queue for every client and source, with severity, SLA, queue, assignment and the AI's status on each case.

02 · HOW IT WORKS

From the first log line to the report, every step on the record

Collect 1
Logs and alerts arrive by push, by HELIOS pulling the vendor's API, or through the signed forwarder.

Normalize 2
Every event is stored once in OCSF form, with its addresses' country, city and network.

Detect 3
Built-in detectors and tested Sigma rules run over each batch and the last 24 hours.

Correlate 4
Findings for the same user, host or IP join one case; severity only ratchets up, never silently down.

Investigate 5
The AI agent analyses the case with read-only tools, cites its evidence, maps ATT&CK techniques and picks the containment.

Decide 6
A fixed stack of rules checks it: kill switch, plan, consent, rulebook, autonomy, evaluation, limits.

Contain 7
Allowed first steps run at once through the client's tools and are confirmed with the vendor; the rest wait for a person.

Report 8
Analysts close with a disposition and reason; clients get reports, daily digests and regulatory notices.

Logs in: 9 vendor collectors
Microsoft Entra ID, Defender XDR, Azure Activity Log, AWS CloudTrail, Google Workspace, Google Cloud, Okta, CrowdStrike Falcon, SentinelOne; plus a push URL per source and a signed Fluent Bit forwarder for syslog and Windows events.

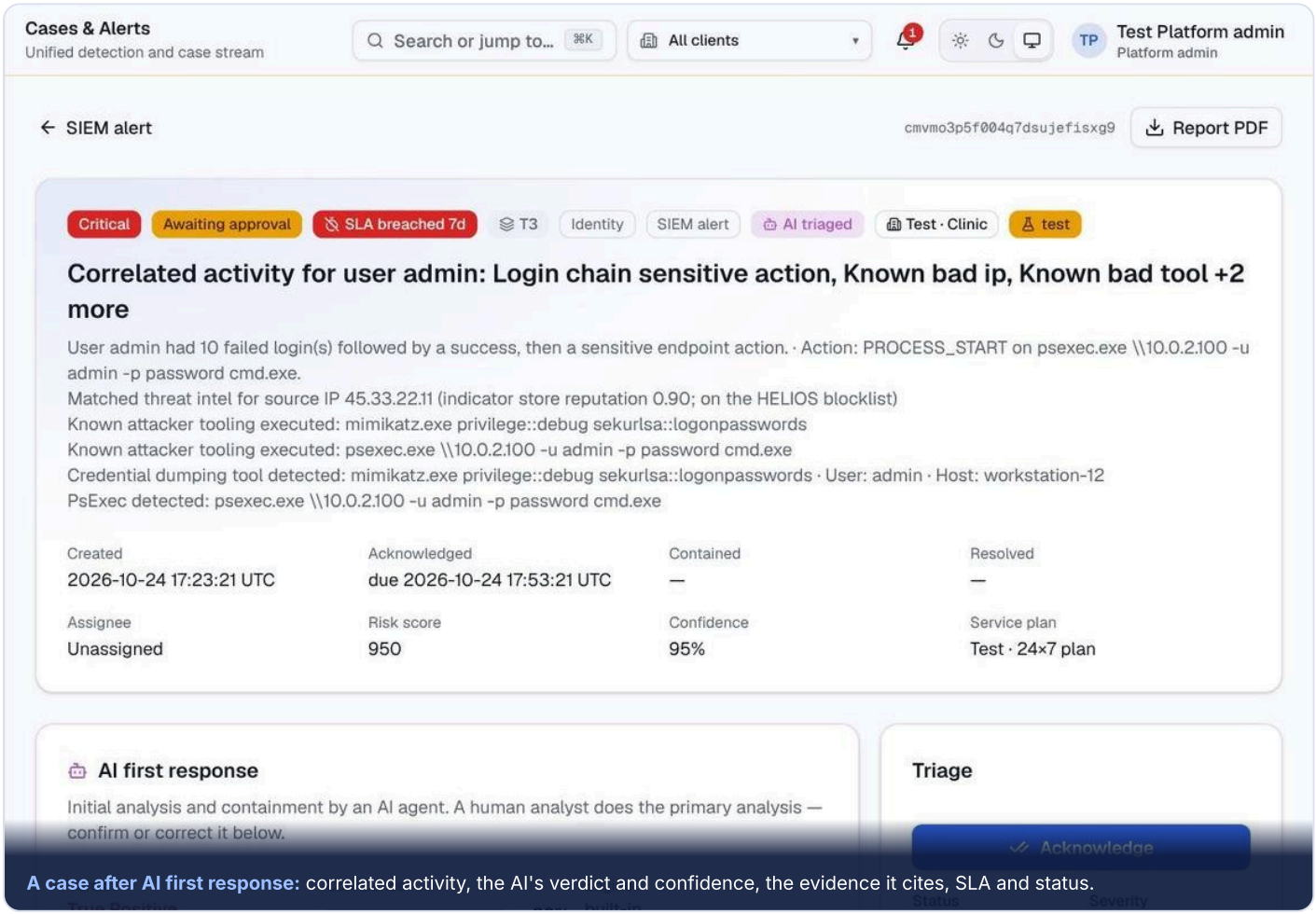
Detections: 11 built in, plus Sigma
Reconnaissance, credential harvesting, lateral movement, persistence, defence evasion, data exfiltration, impact, threat-intel matches, anomalous actions, impossible travel and sign-in chains; Sigma rules backtested before they go live.

Actions out: 7 native connectors
Defender for Endpoint, Entra ID, Exchange Online, CrowdStrike, SentinelOne, Okta and Cloudflare, or a signed webhook to anything else. Each action is dry-run-able, time-boxable and rolled back from the case.

AI does the first minutes
Triage, evidence, the containment decision and the initial containment itself, around the clock, in seconds.

People own every decision after
Analysts confirm, investigate, eradicate and close. Anything beyond initial containment waits for a person.

Every step is evidence
Each proposal, rule, approval and action is in a hash-chained audit trail that can't be quietly changed.



A case after AI first response: correlated activity, the AI's verdict and confidence, the evidence it cites, SLA and status.

03 · THE GOVERNING PRINCIPLE

The AI contains first, inside rules people approve

AI executes
Investigates, picks the containment and runs the initial steps itself, in seconds, when the rules allow.

HELIOS governs
A deterministic policy engine, not the AI, decides every action against the rules in force, then checks again as it acts.

The client authorises
Each client's rulebook says what may run on its own, what needs a yes and what never happens.

The audit trail proves
Every decision records the exact rulebook version and fingerprint it was made under.

What the AI may do on its own

Only the first, reversible steps, each undoable from the case, and only when every rule allows it:

Isolate a host · Block an IP · Block a sender · Quarantine a file · Collect logs

Always proposed for a person, whatever the rules say:

Disable an account · Reset a password · Kill a process · Purge mail · Collect forensics · Revoke an agent

Never, under any rule: containing a never-isolate asset or a break-glass account, or an action the client forbids.

- Each action the AI runs is announced at once to the SOC's managers, the case's watchers and the client's admins.
- Each can be rolled back from the case in one click; IP blocks and account actions can expire on their own after the client's set hours.
- Initial containment buys time. Eradication, recovery and closing the case stay with analysts.

How every action is decided

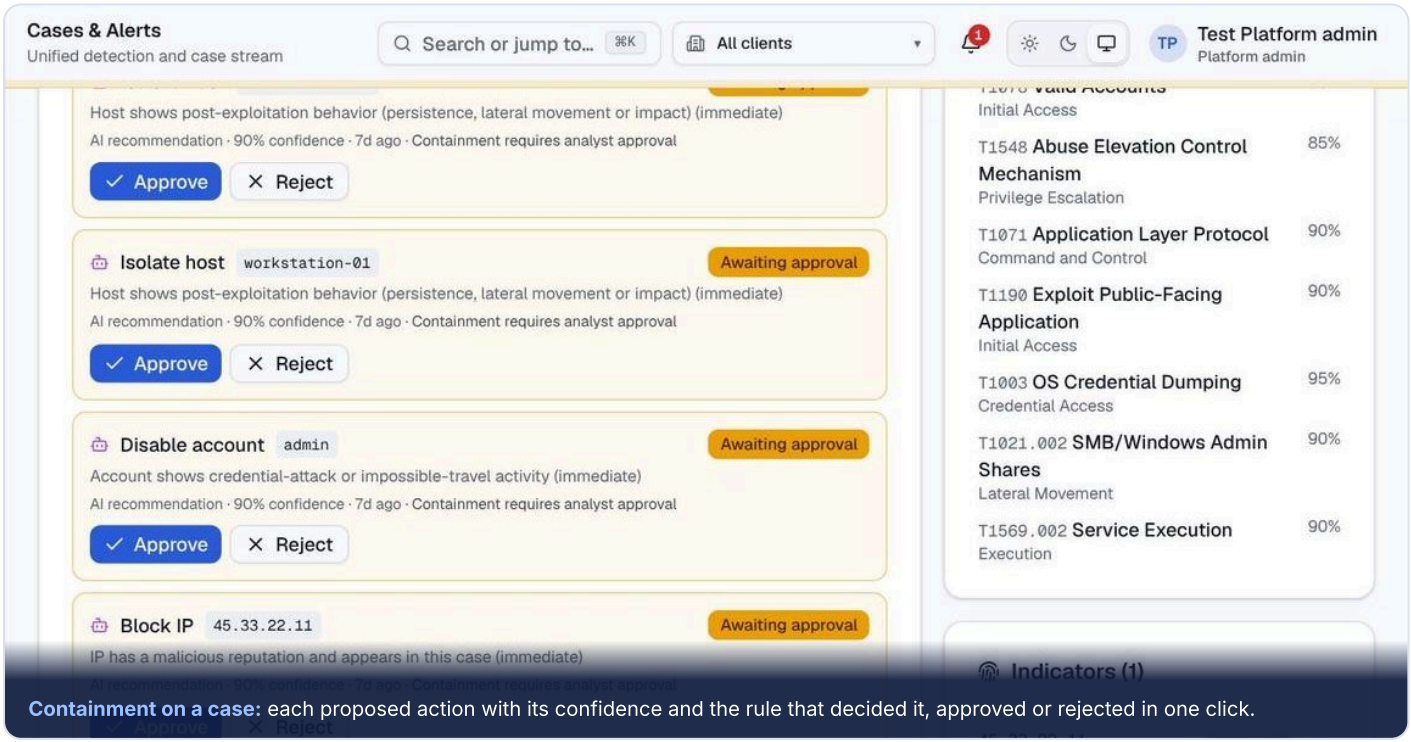
A fixed stack; the most restrictive layer wins and is named on the case:

1 Grounding	The target must appear in the case's evidence
2 AI safety	Evidence aimed at the AI sends it to a person
3 Kill switch · circuit breaker	Stops all AI action at once
4 Plan · client consent	What the client bought and agreed
5 Client rulebook	Assets, accounts, modes, hours, limits
6 Autonomy ladder	Earned per client and per action
7 Agent · model · rate	Confidence bar, evaluation, hourly cap

Checked twice
Just before acting, an AI action nobody approved is checked again against the rules in force *now*. If the rules moved on, it waits for a person.

Monitored all the time
Every action is confirmed with the vendor, notified to the SOC and the client, and re-checked every five minutes.

Stopped on any violation
Anything outside the approved rules is blocked, the client's automatic containment pauses, and the on-call analyst is paged.



Containment on a case: each proposed action with its confidence and the rule that decided it, approved or rejected in one click.

04 · CHANGE CONTROL

No AI takeover: rules change only when people approve

No AI model, provider or agent can change a rule, raise its own autonomy or approve anything. Models supply analysis; HELIOS's code decides. Every change to what containment runs under is a request with a fingerprint, approved before it takes effect. Until then the approved rules stay in force.

Change	Takes effect after
New rulebook version	Client signs **and** HELIOS approves
Allowlist entry added or removed	Client **and** HELIOS
AI autonomy raised (ladder)	Client **and** HELIOS
Client's AI consent raised	Client **and** HELIOS
Containment agent given more room	A second HELIOS approver
Platform limits widened, kill switch off	A second HELIOS approver
Kill switch on, lowering autonomy or consent	**At once**: stopping never waits

How a rule change goes

1. **Draft** the change, from a template, the editor, YAML or the client's Git repository.
2. **Review**: approvers see exactly what changes against the version in force.
3. **Dry run**: the last 30 days of AI decisions replayed under the new rules.
4. **Client approves**: its admin signs, or HELIOS records the client's written instruction.
5. **HELIOS approves**: an approver other than whoever asked.
6. **In force**, checked unchanged since the request, fingerprinted and audited. Edits after submission void the approvals.

Four eyes, always

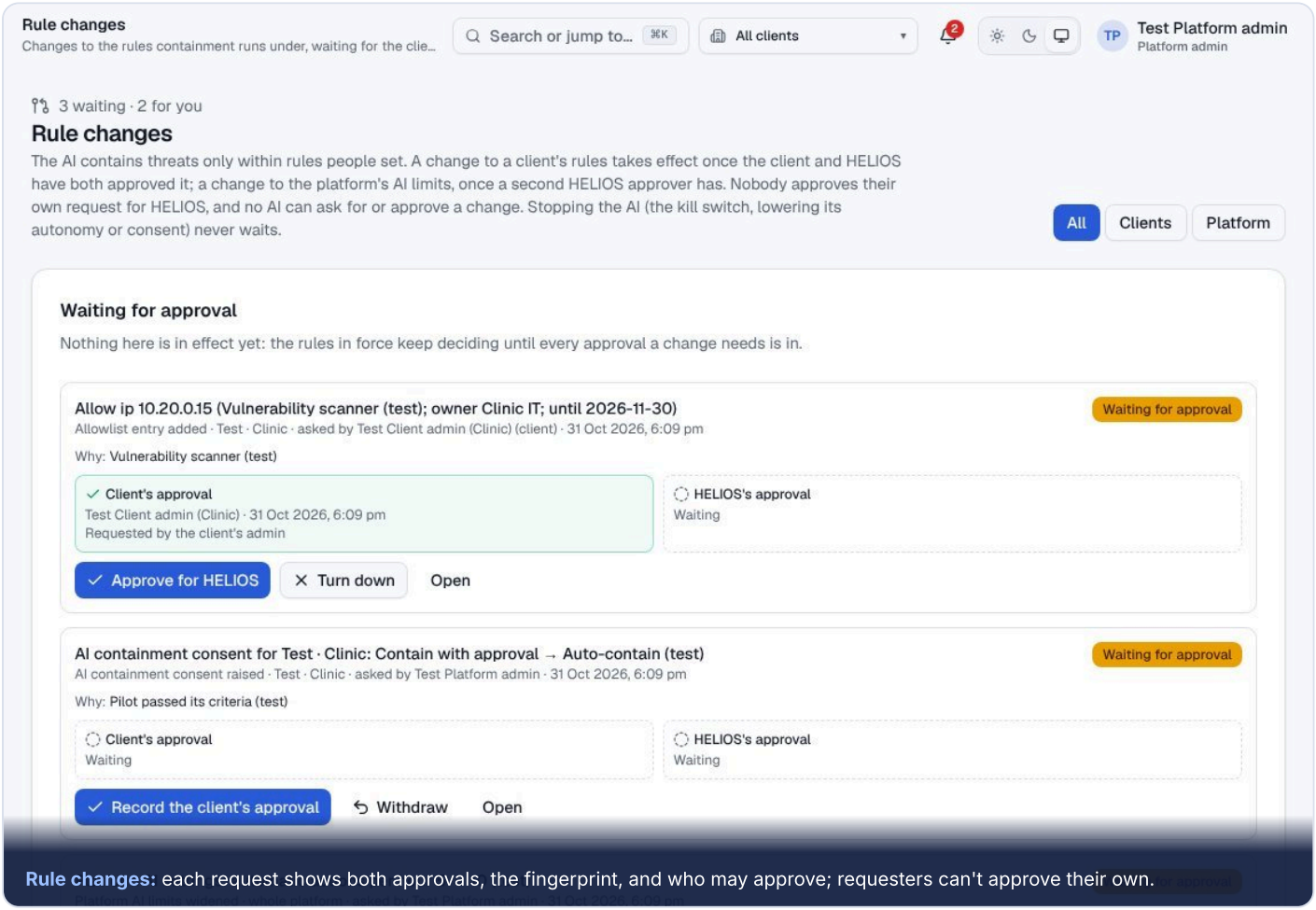
Nobody approves their own request for HELIOS; whoever records a client's instruction can't also approve for HELIOS.

Tamper-evident rules

A rulebook edited outside HELIOS no longer matches its fingerprint: automation for that client stops and the SOC is told.

One place to decide

Rule changes waiting, approved, turned down or lapsed, for the client and for HELIOS, on one page.



Rule changes: each request shows both approvals, the fingerprint, and who may approve; requesters can't approve their own.

05 · CAPABILITIES

Everything a managed SOC runs on, in one platform

Cases and alerts
One queue for every source with tier 1–3 escalation, assignment, watchers, @mentions, internal or client-visible discussion, SLA clocks and correlation.

Log collection
Push, pull from nine vendor APIs, or a signed forwarder; a durable queue that takes clients in turn; OCSF storage; dead-letter replay; quiet sources open cases.

Detection engineering
Eleven built-in detectors; Sigma rules compiled, backtested, tested, then made live; tuning per client with reasons and expiry.

AI agents
Triage, phishing, threat-intel and investigation agents with cited evidence, grounding checks, prompt-injection defences and model evaluations.

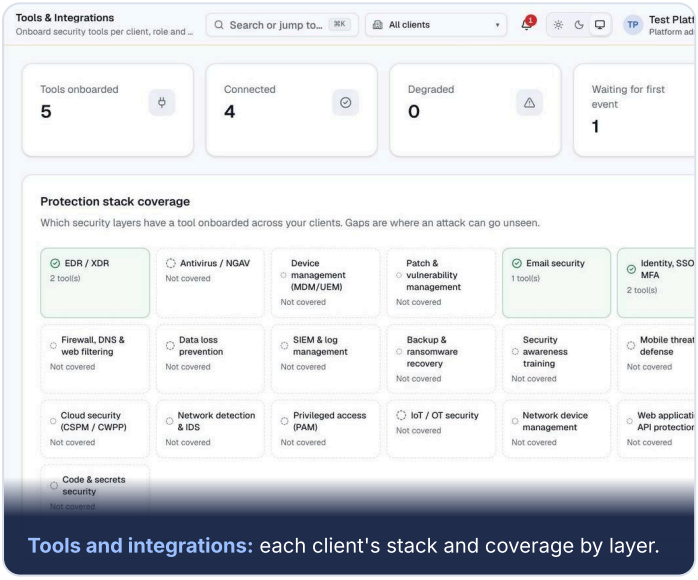
Response connectors
Defender for Endpoint, Entra ID, Exchange Online, CrowdStrike, SentinelOne, Okta and Cloudflare, or a signed webhook; dry run, rollback, time boxes.

Investigations
Upload a log bundle for a root-cause pipeline; an investigation agent works a case with read-only tools and cites what it read.

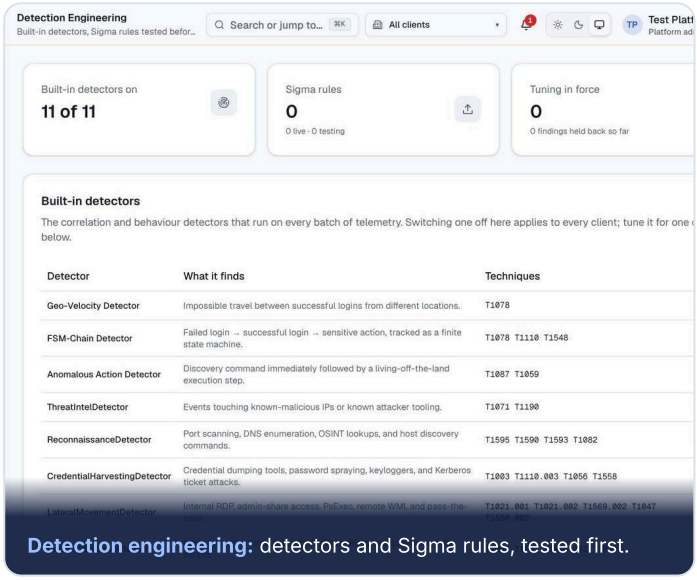
Platform
Two-step sign-in and single sign-on, a REST API with scoped tokens, an installable app for desktop and phone, light and dark themes, a command palette.

Case work
Assignment, tiers, watchers, @mentions, client-visible or internal comments, sharing, SLA clocks, related cases, PDF case reports.

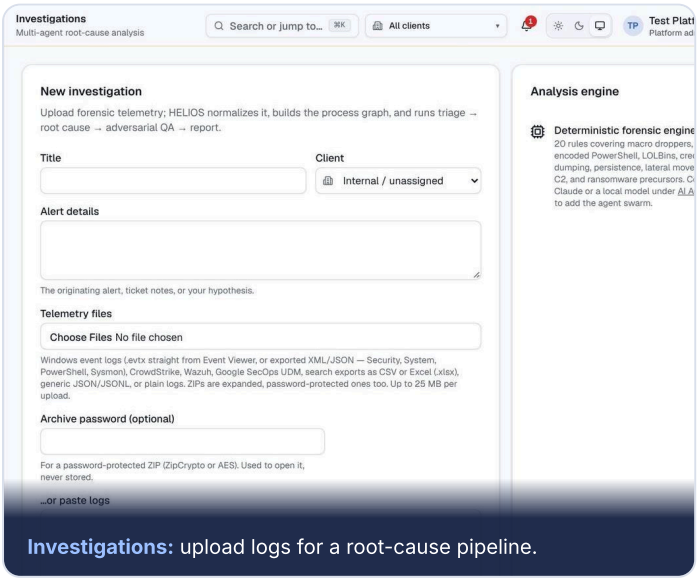
Integrations
A catalog of 79 security products across every protection layer, with each client's live stack, coverage gaps and source health.



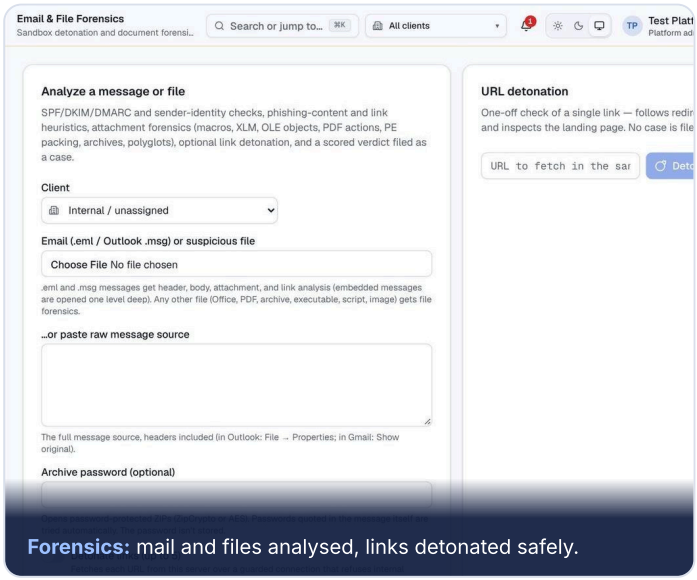
Tools and integrations: each client's stack and coverage by layer.



Detection engineering: detectors and Sigma rules, tested first.



Investigations: upload logs for a root-cause pipeline.



Forensics: mail and files analysed, links detonated safely.

Email and file forensics

Headers, links, attachments, macros, archives and QR codes analysed; links detonated through a vetted proxy.

Threat intelligence

A shared indicator store with feeds, providers, a blocklist and IP locations; an attack graph that finds chains across cases.

Playbooks and runbooks

Response playbooks with approval steps; runbooks that attach to matching cases and are worked as checklists.

SOC operations

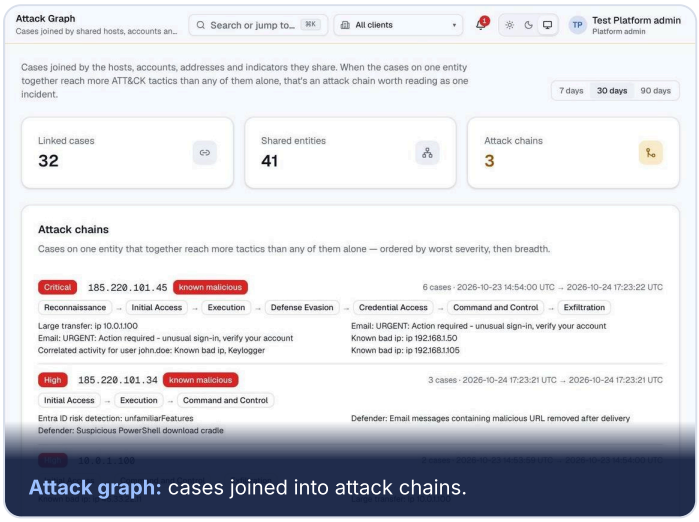
On-call rota with escalating pages and handoffs, weekly QA of what the AI did alone, daily digests.

Data retention

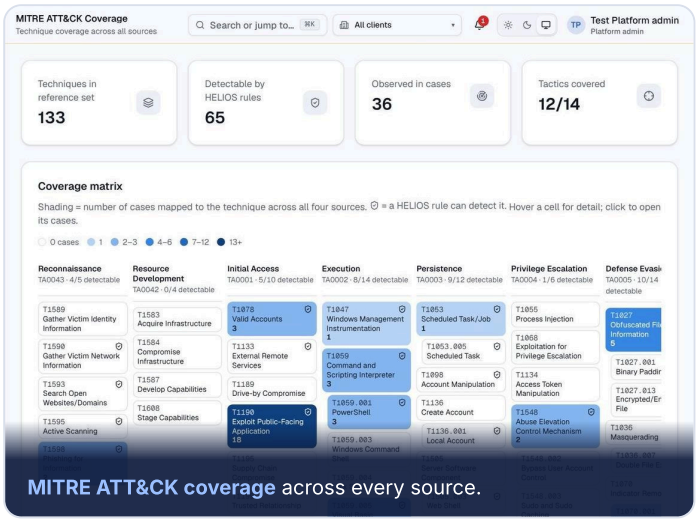
Per-client searchable and kept periods, an encrypted archive in India, legal holds, monthly partitions.

Build, price and bill

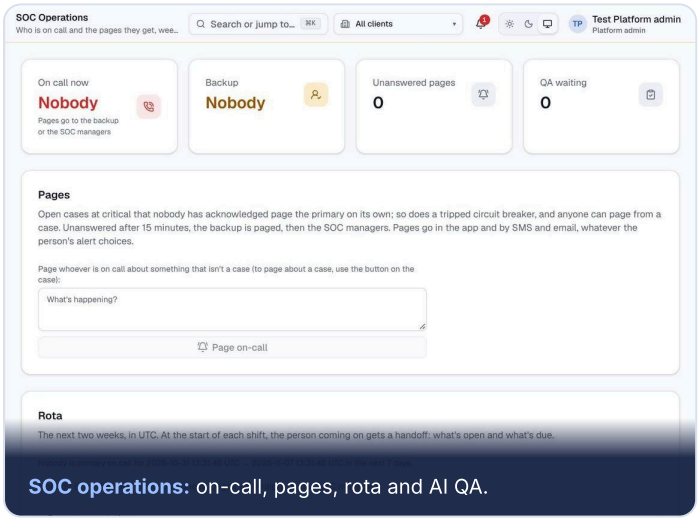
Quote a client's stack with an advisor; pilots measured from HELIOS's own records; contracts signed in the app; GST invoices.



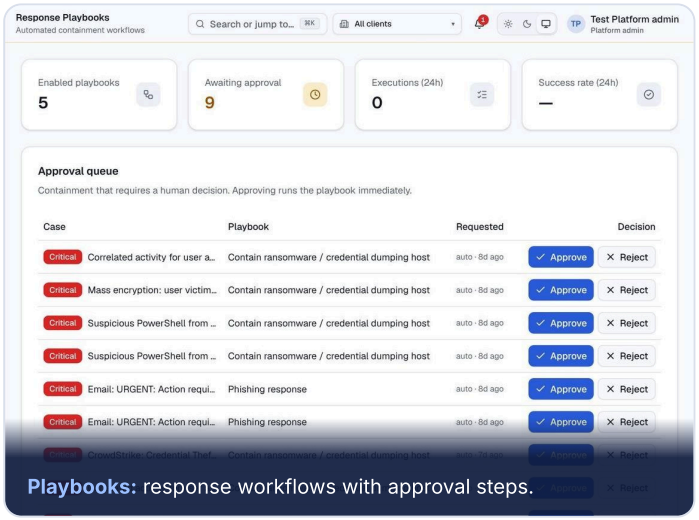
Attack graph: cases joined into attack chains.



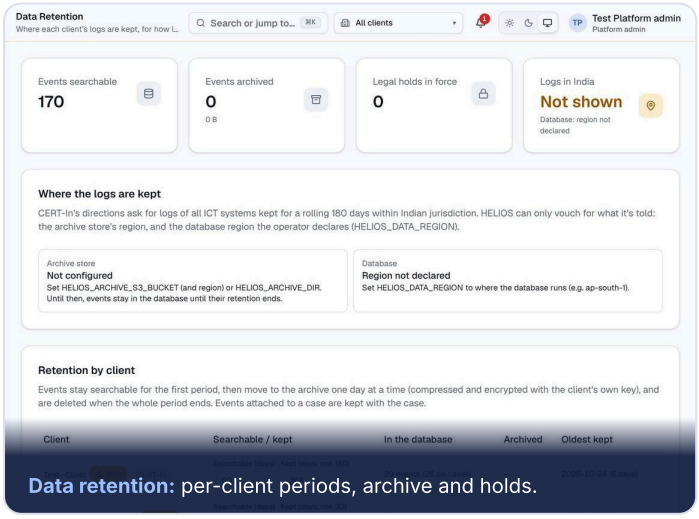
MITRE ATT&CK coverage across every source.



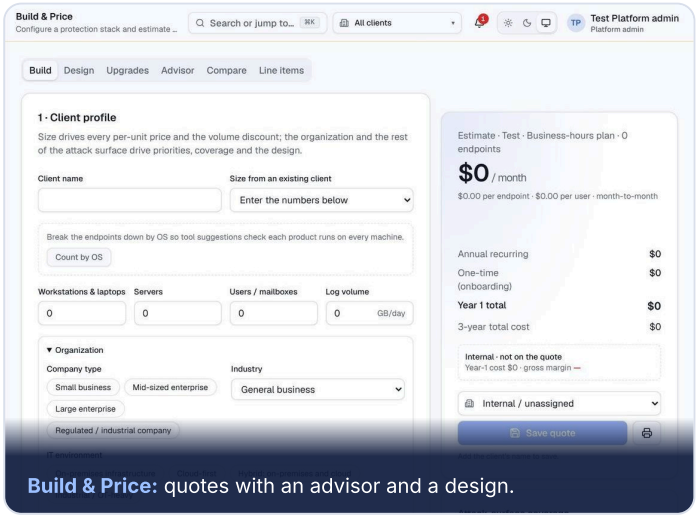
SOC operations: on-call, pages, rota and AI QA.



Playbooks: response workflows with approval steps.



Data retention: per-client periods, archive and holds.



Build & Price: quotes with an advisor and a design.

06 · THE CLIENT PORTAL

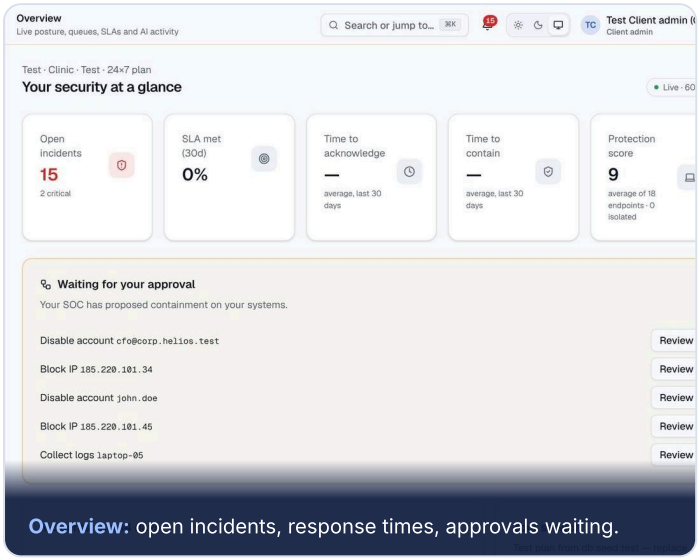
Clients see what was done, approve what matters, set the rules

See
Their incidents with the AI's evidence, endpoints and coverage gaps, service reports and a daily digest.

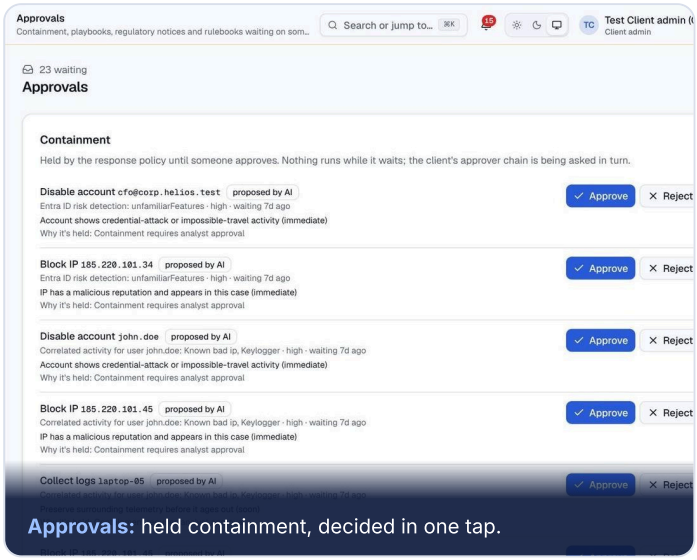
Approve
Held containment in one tap, by app, email, SMS or WhatsApp, along their own approver chain.

Set the rules
Their rulebook, allowlist, AI consent and data handling; every change needs their approval and HELIOS's.

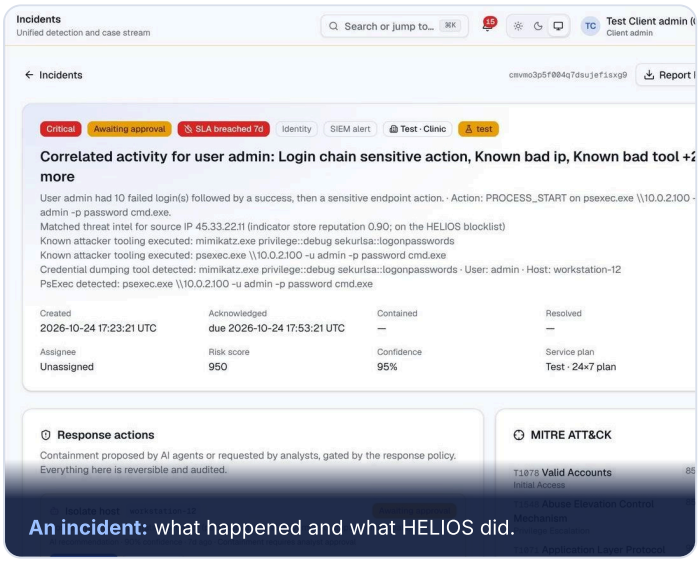
Meet regulators
CERT-In reports and DPDP notices drafted from the case, approved by them, filed on time.



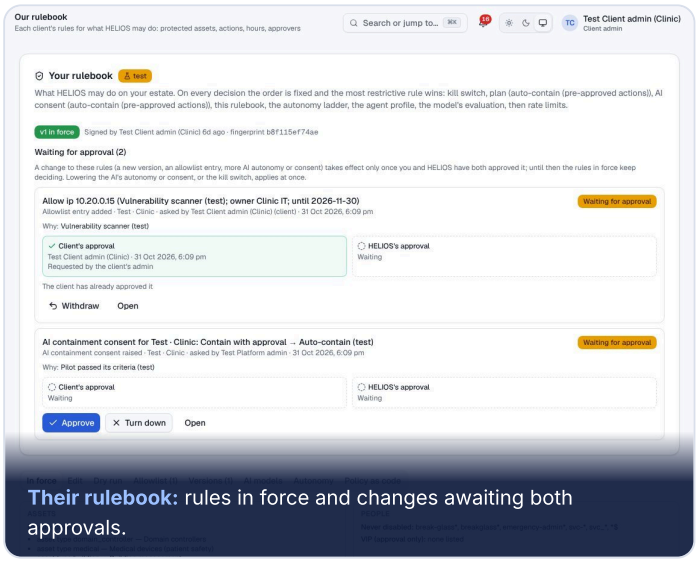
Overview: open incidents, response times, approvals waiting.



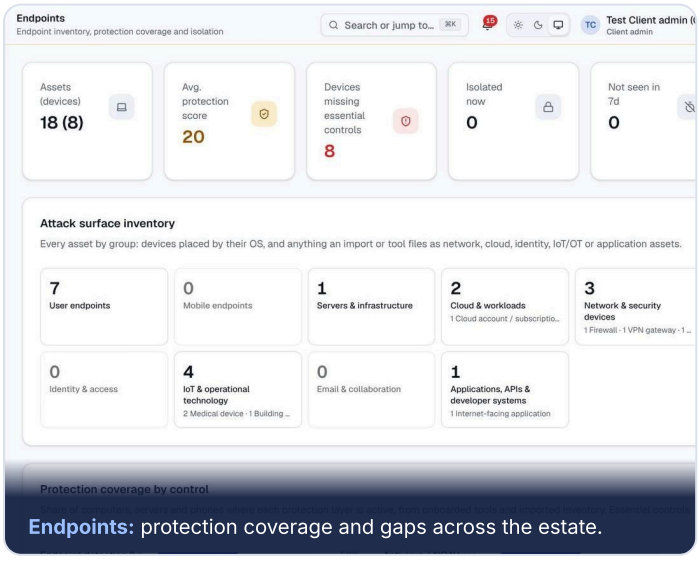
Approvals: held containment, decided in one tap.



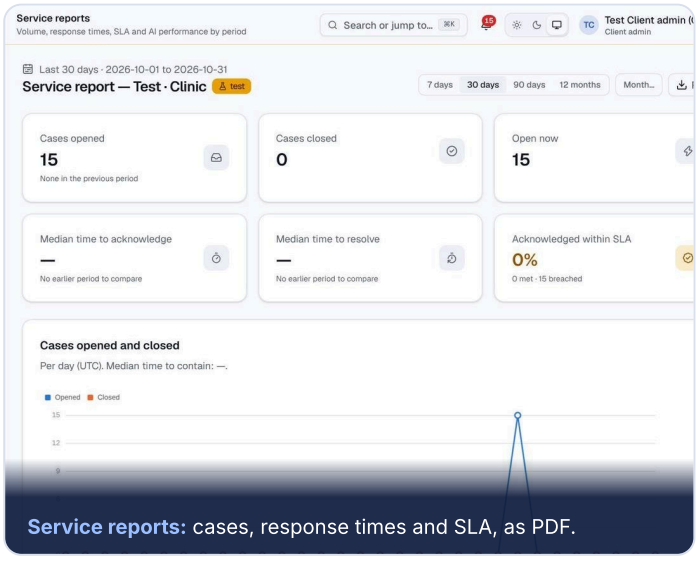
An incident: what happened and what HELIOS did.



Their rulebook: rules in force and changes awaiting both approvals.



Endpoints: protection coverage and gaps across the estate.



Service reports: cases, response times and SLA, as PDF.

07 · TRUST AND SECURITY

Built to be trusted with a client's estate

The client's rules bind everyone

A versioned, fingerprinted rulebook decides what may happen on the estate. Hard rules bind analysts and playbooks too, re-checked when acting.

Evidence, not assertions

Every AI finding cites the evidence it rests on. A grounding check drops claims and targets the evidence doesn't contain.

Attacker text stays attacker text

Text aimed at the AI is flagged and fenced off; a fooled model can't downgrade a case, and proposals from steered evidence wait for a person.

Autonomy is earned

Shadow mode first; promotion only on a clean record and both approvals; automatic demotion after a bad week; weekly QA by people.

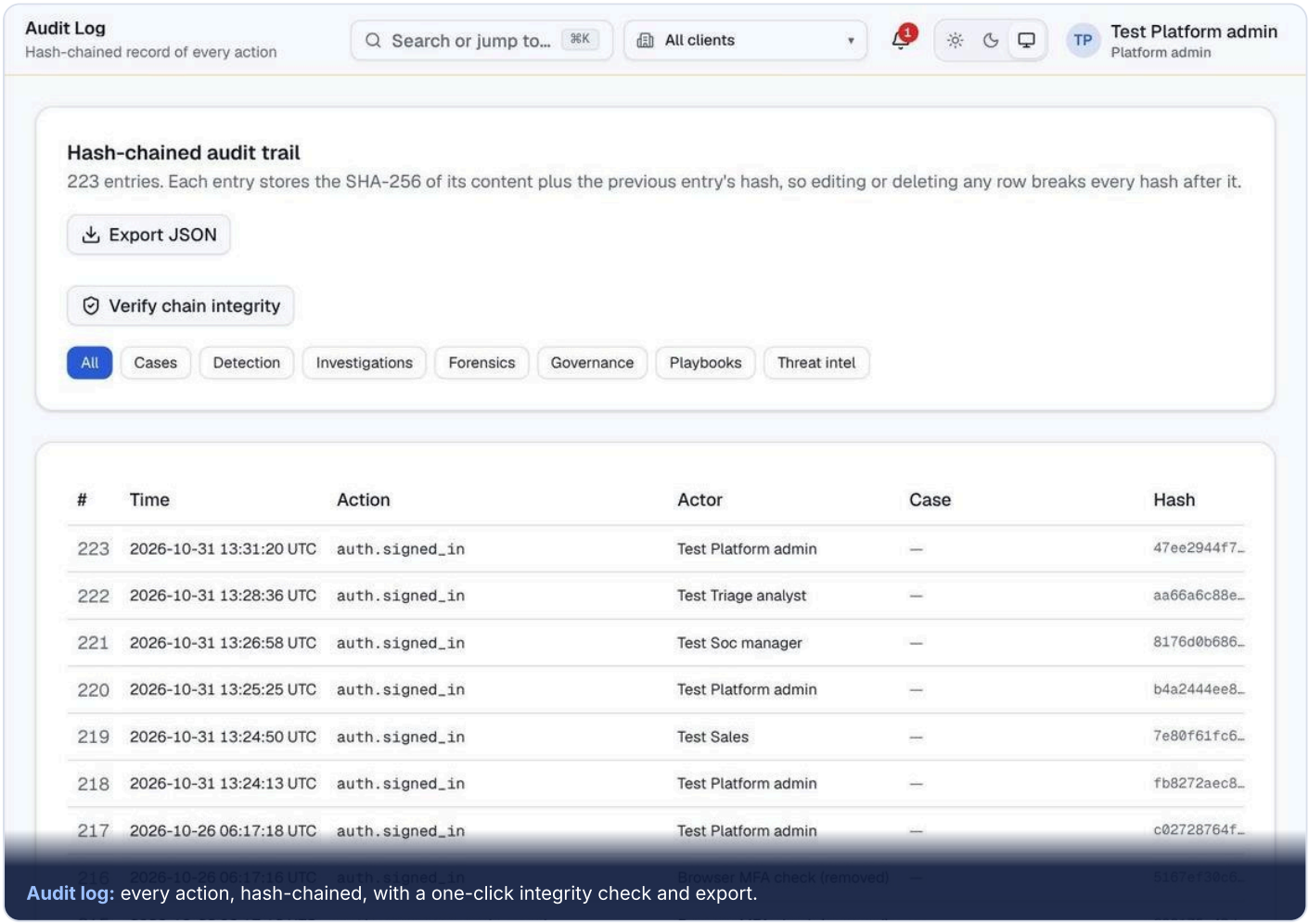
Actions are real or they don't count

A connector checks the target, acts once, and reads the vendor's state back before an action counts as containment.

Each client's data stays theirs

Isolation enforced by the database itself; each client's credentials sealed with its own key, destroyable at offboarding.

Layer	Security built in
Sign-in	Two-step sign-in, single sign-on, lockout, server-side permission checks on every page and action
Data	Row-level isolation per client; AES-256-GCM sealed secrets under per-client keys wrapped by AWS KMS
Database	The app's role can't change the schema, bypass isolation or alter the audit log
Web	Per-request Content Security Policy, strict security headers, HSTS, upload limits
Network	No fetches to private or cloud-metadata addresses; Kubernetes default-deny policies
Containers	Distroless, non-root, read-only, no capabilities, Pod Security “restricted”
Audit	Hash-chained trail; changing any entry breaks every hash after it



Audit log: every action, hash-chained, with a one-click integrity check and export.

08 · ROLES AND ACCESS

Eleven roles, each seeing exactly what it needs

Each person has one role, which decides every page, button and API call they can use, checked on the server. Client users are also confined to their own organisation by the database itself.

Platform admin Leadership
Runs the platform: accounts, settings, AI configuration, price book, keys.

SOC manager Leadership
Runs the SOC: queues, SLAs, approvals, on-call, AI autonomy, rule approvals.

Tier 1 analyst Analysts
Triages new cases, confirms or dismisses, escalates, requests containment.

Tier 2 analyst Analysts
Investigates, runs forensics and threat intel, shares with clients.

Tier 3 responder Analysts
Leads major incidents, approves containment, works regulatory notices.

Threat hunter Specialists
Hunts across telemetry and intelligence, feeds indicators back.

Detection engineer Specialists
Builds and tunes detections, Sigma rules and playbooks.

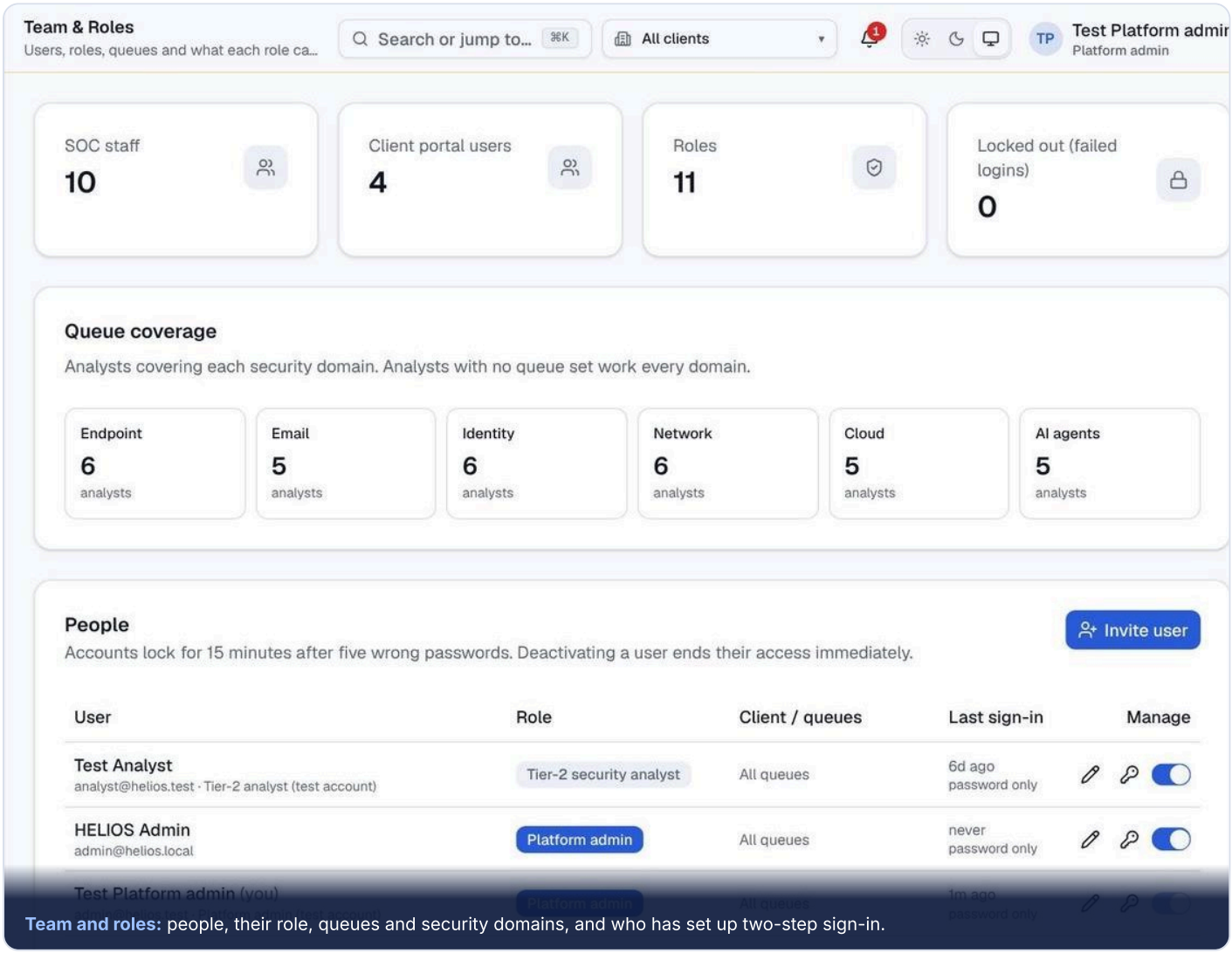
Auditor Oversight
Reads everything, verifies and exports the audit trail; changes nothing.

Account manager Commercial
Quotes, pilots, contracts and billing for clients.

Client admin Client
Their own incidents, approvals, rulebook and rule changes, reports, security tools, alerts and contract.

Client viewer Client
Their own incidents, endpoints, reports and rulebook, read-only, with no approvals or changes.

Who approves what
Containment: tier 3, SOC manager, client admin. Rule changes: client admin and a HELIOS approver (SOC manager or admin).



Team and roles: people, their role, queues and security domains, and who has set up two-step sign-in.

09 · YOUR CHOICE OF AI

Cloud, in your own cloud account, or on your own hardware

Every agent works with no model at all (a built-in deterministic engine). Models add analysis. Whatever the model, it never decides what runs: the policy engine, the client's approved rules and change control do. Each client's rulebook can say which models may read its evidence.

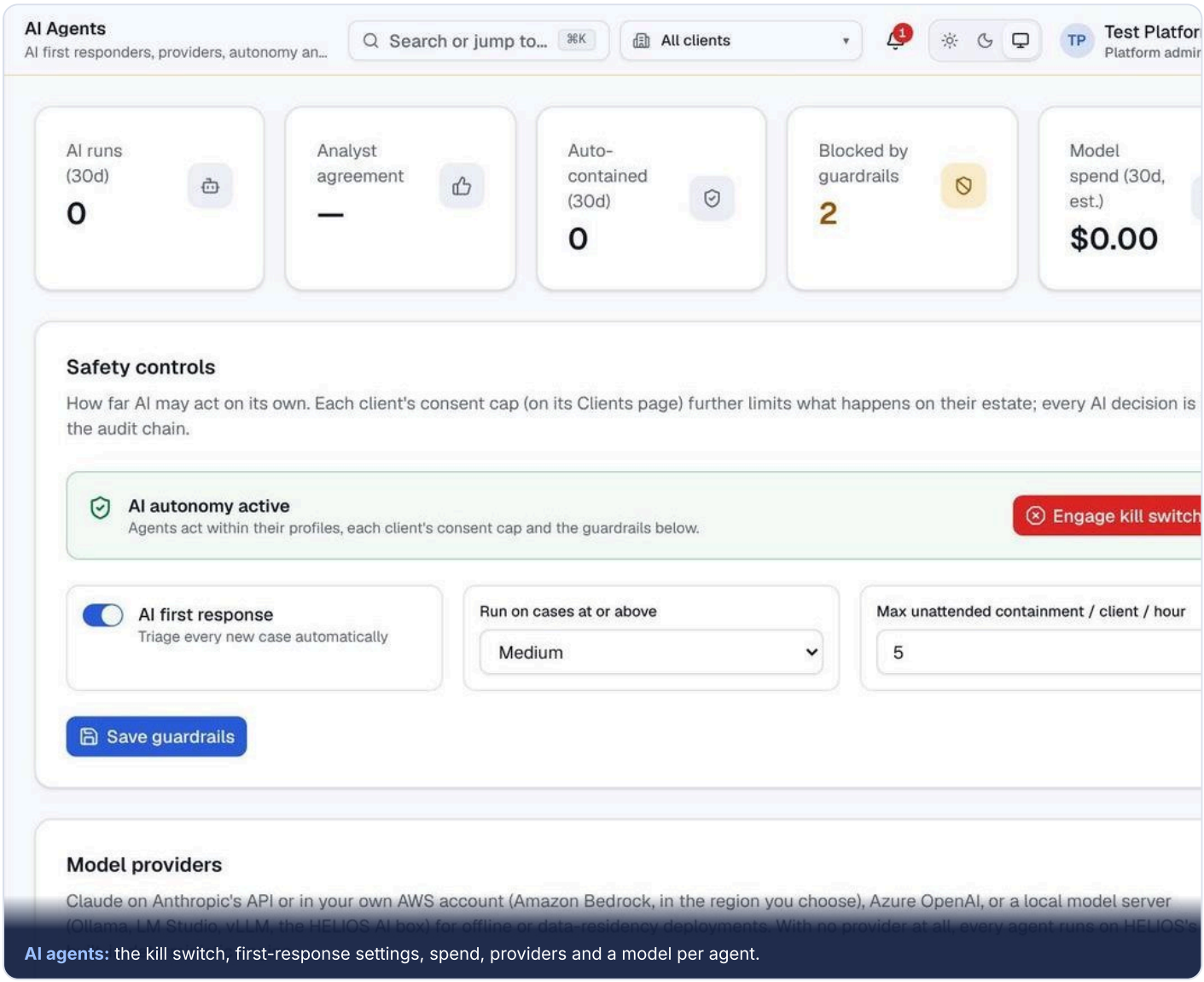
Where the model runs	Options	Best for
Anthropic API	Claude, set with an API key	The simplest start; strongest triage and investigation
Your AWS account	Claude in Amazon Bedrock, Mumbai (ap-south-1)	Evidence and billing stay in your AWS account, in India
Your Azure tenant	Azure OpenAI, Central India	Organisations standardised on Microsoft
Your Mac or server	Ollama, LM Studio, vLLM (OpenAI-compatible)	Testing offline; full data control
The client's site	The HELIOS AI box: Ollama or vLLM behind Caddy with API key and mutual TLS	Clients whose rules say "on-premises AI only"

Evaluated first
A model acts on its own only after passing HELIOS's evaluation on a golden set.

Data handled
Personal data is masked before cloud models see it, per client.

Cost visible
Spend per run and per client, with prompt caching to cut repeat cost.

Kill switch
One switch stops all AI action at once; turning it off needs a second approver.



AI agents: the kill switch, first-response settings, spend, providers and a model per agent.

10 · DEPLOYMENT

From a laptop to a hardened cloud, the same images

On a Mac or one server
`./deploy/compose/setup.sh` then `docker compose up -d --build`: Postgres, migrations, web and worker, each non-root and read-only, ports on localhost only.

On Kubernetes
Kustomize manifests: autoscaled web, worker, a migrate Job, Pod Security "restricted", default-deny network policies, no metadata access.

In the cloud
Recommended: AWS Mumbai with EKS, RDS Multi-AZ, ALB + WAF, KMS, Secrets Manager and S3 Object Lock; disaster recovery in Hyderabad.

Users and clients
Browser or installed app

Route 53 · AWS WAF
Managed rules, rate limits

Application Load Balancer
TLS 1.3, ACM certificate

▼ private subnets, three availability zones ▼

EKS · helios-web ×2–10
Stateless, autoscaled, Pod Security restricted, read-only, non-root

EKS · helios-worker ×2
Ingest queue, collectors, retention, escalation, the containment monitor

helios-migrate Job
Migrations as the schema owner, then least-privilege grants

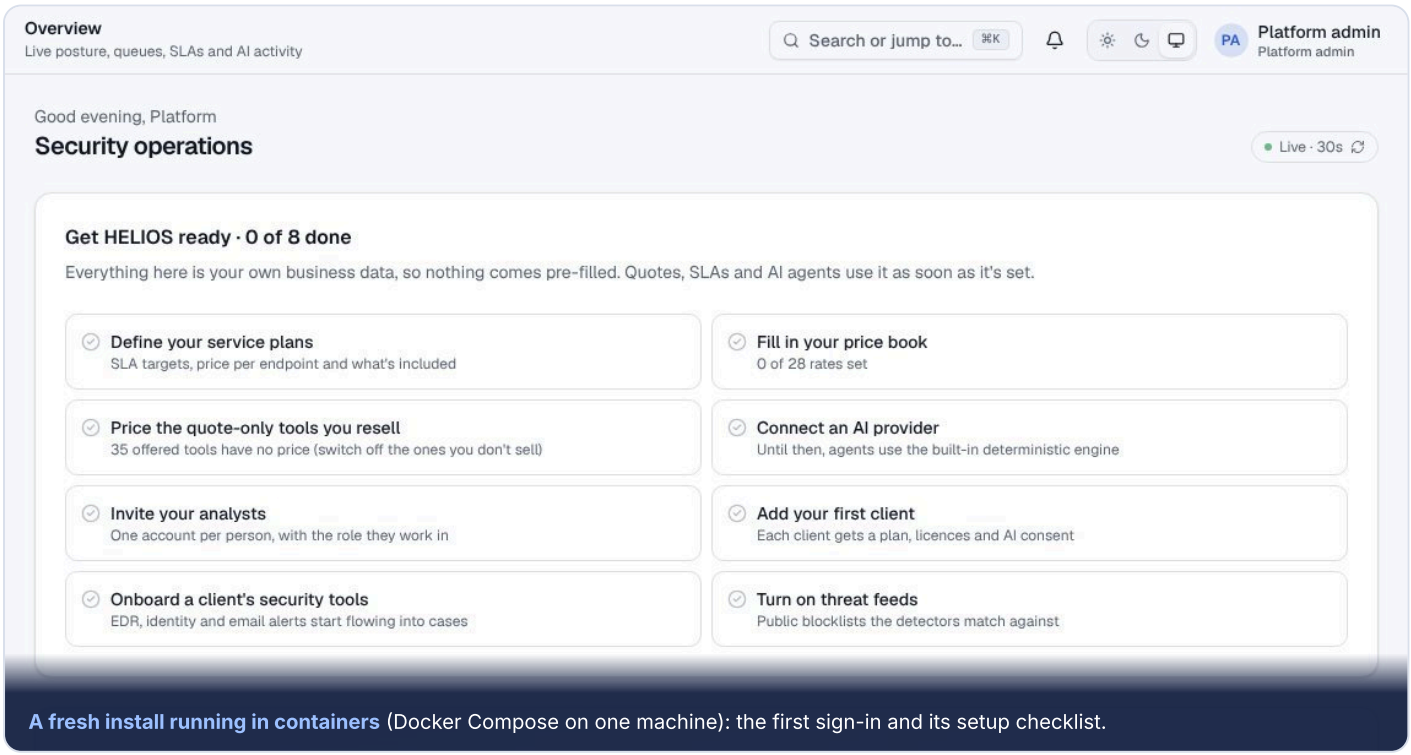
RDS PostgreSQL 16
Multi-AZ, KMS-encrypted, TLS only, 35-day point-in-time restore, isolated subnets

Secrets Manager · KMS
Secrets via External Secrets; master key decrypted by KMS at start-up

S3 · SES · Bedrock
Log archive with Object Lock, mail, Claude in-region

GuardDuty · Security Hub · CloudTrail
The platform watched like a client

Step	What you do
1 Guardrails	Production account, India-only regions, CloudTrail, GuardDuty, Security Hub
2 Network and data	VPC over three zones; RDS in isolated subnets; run `roles.sql` once
3 Secrets and keys	KMS keys; the master key's ciphertext and database URLs in Secrets Manager
4 Cluster and images	EKS with the load balancer controller and External Secrets; build both architectures to ECR
5 Deploy	Fill in the AWS overlay, `kubectl apply -k`, wait for the migrate Job, point DNS
6 Before the first client	Require two-step sign-in, connect SSO, test a restore, run a penetration test



A fresh install running in containers (Docker Compose on one machine): the first sign-in and its setup checklist.

11 · REGULATORY

CERT-In, DPDP and ISO 27001, from the same records

CERT-In: six hours
Cases of a reportable type start the clock on their own. The report is drafted from the case, approved by the client and filed; updates follow until closed.

DPDP breach notices
For clients who are Data Fiduciaries: the Board's intimation and notices to each affected person, drafted, approved and recorded.

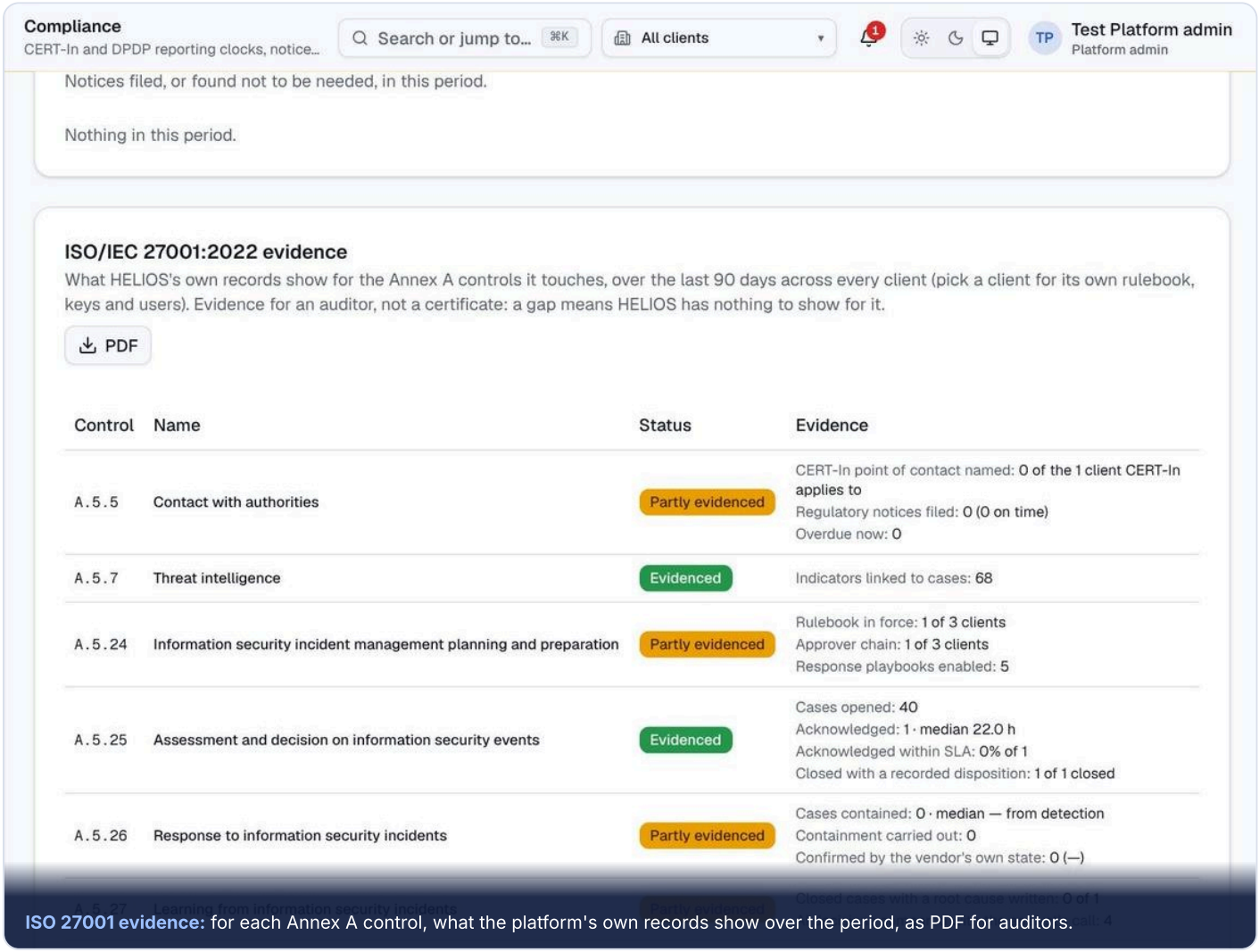
180 days in India
Logs kept searchable and archived in India per client, with legal holds; partitions past retention dropped whole.

ISO 27001 evidence
For fifteen Annex A controls, what the platform's own records show over any period: cases, containment, filings, sign-in, keys.

Contracts that match
Each contract records the AI autonomy agreed, the rulebook version in force, the liability cap for automated containment and the DPA.

Data residency for AI
A client's rules can keep its evidence with region-locked or on-premises models only, with personal data masked.

Obligation	Clock	What HELIOS does
CERT-In incident report	6 hours from noticing	Starts the clock for reportable case types at or above the client's severity; drafts the report; client approves; filing recorded
CERT-In updates	Until closed	Follow-up reports from the case as it develops
DPDP: the Board	Without delay	Intimation drafted from the case; client's own target for "without delay"
DPDP: each person affected	Without delay	Notices with the client's contact, approved and recorded
Log retention	180 days, in India	Per-client periods, encrypted archive, legal holds that stop deletion



ISO 27001 evidence: for each Annex A control, what the platform's own records show over the period, as PDF for auditors.

12 · GETTING STARTED

From install to the first protected client

Set up HELIOS (once)

1. Deploy: Docker Compose on a Mac or server, or Kubernetes in the cloud.
2. Sign in as the first admin; set up two-step sign-in; fill in Settings.
3. Define service plans and the price book.
4. Connect an AI provider and run its evaluation (or start with the built-in engine).
5. Invite the team, each with one role.
6. Turn on threat feeds.
7. Require two-step sign-in for staff and connect single sign-on.

Bring on a client

1. Quote with Build & Price; run a measured pilot if they want one.
2. Create the client with its plan, licences and AI consent; invite its admin.
3. Onboard its security tools; watch sources go healthy.
4. Draft its rulebook from an industry template; dry-run it; the client signs and HELIOS approves.
5. Start shadow mode: the AI is measured against analysts before it acts alone.
6. Sign the contract in the app; invoices follow each billing period.

When a threat lands

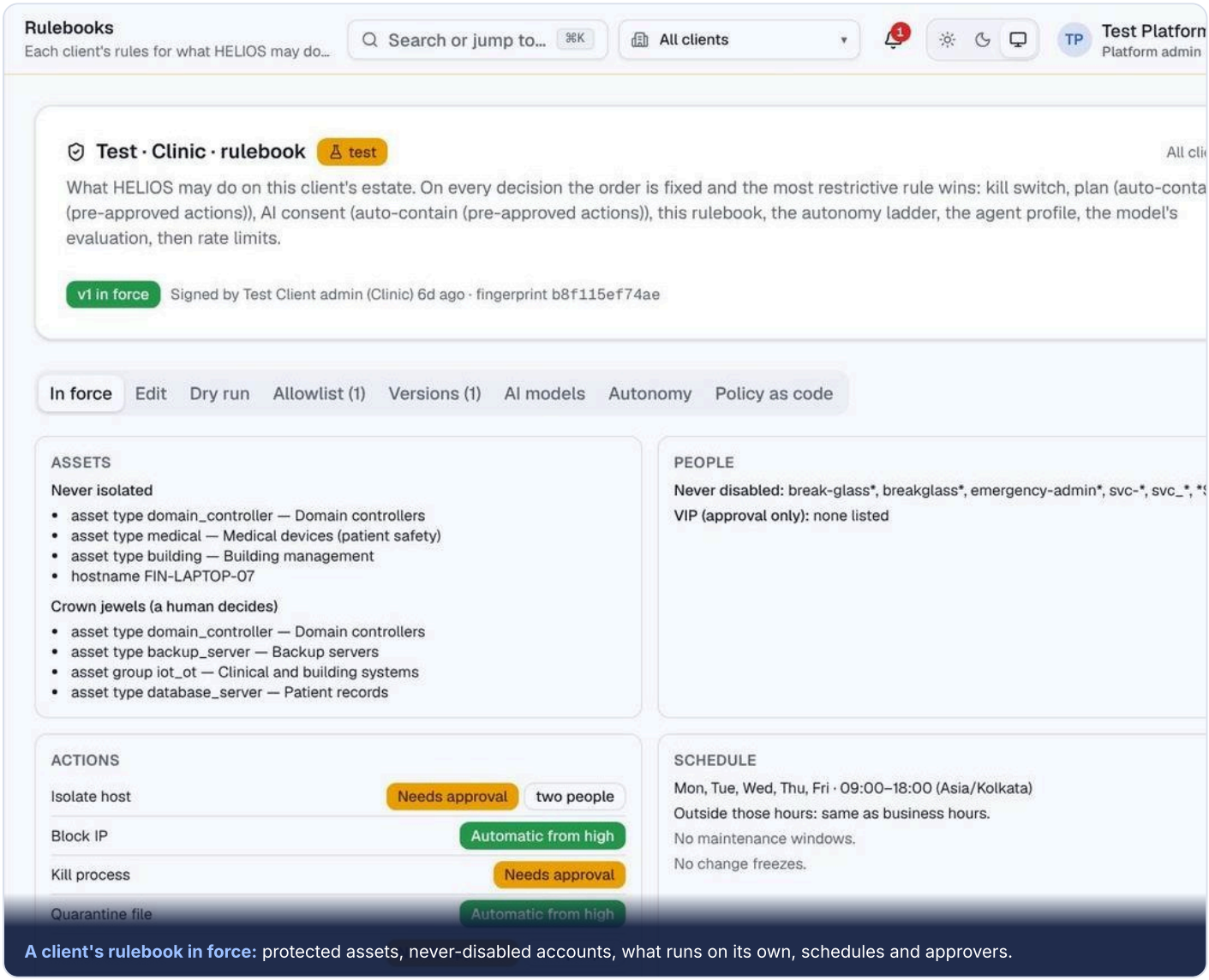
The case opens, the AI investigates and contains within the rules in minutes, the client and the SOC are told at once, and analysts take it from there.

When rules must change

Ask on the rulebook page; both sides see the diff and the dry run; it takes effect when the client and HELIOS approve.

When something looks wrong

Pull the kill switch, or lower a client's autonomy or consent: it applies at once, no approval needed. Then review the case and the audit trail.



A client's rulebook in force: protected assets, never-disabled accounts, what runs on its own, schedules and approvers.